

Manual: Segurança da Informação

ISO 27001/27002, Riscos (31000/27005), Continuidade, Incidentes, Zero Trust, Criptografia, ICP-Brasil, Redes, Malwares, OWASP Top 10, Nuvem e LGPD

CHANCELA EDITORIAL YLUNA85 LABS

Preparação Conjunta: Auditor Fiscal (TI) & Agente de Tributos Estaduais

Revisão Ortográfica e Glossário Geral de Siglas

Material de livre circulação interna. Revisado em Português Brasileiro (pt-BR).

1. Princípios de Segurança e Gestão com ISO/IEC 27001 e 27002

A Segurança da Informação visa proteger os ativos de informação contra uma ampla gama de ameaças, garantindo a continuidade do negócio, a conformidade legal e a mitigação de riscos operacionais. O pilar clássico de segurança é a Tríade CID (Confidencialidade, Integridade e Disponibilidade), complementada pelos princípios de Autenticidade, Irretratabilidade / Não Repúdio e Conformidade. A governança corporativa de segurança é padronizada internacionalmente pela família ABNT NBR ISO/IEC 27000.

- A Tríade CID e Princípios Básicos

Confidencialidade: Garantia de que a informação é acessível exclusivamente por pessoas, entidades ou processos autorizados; Integridade: Salvaguarda da exatidão e completude da informação e dos métodos de processamento, impedindo alterações não autorizadas; Disponibilidade: Garantia de que os usuários autorizados tenham acesso à informação e aos ativos correspondentes sempre que necessário; Autenticidade: Garantia da veracidade da identidade do emissor; Não Repúdio / Irretratabilidade: Impossibilidade de o autor negar a autoria de uma transação ou mensagem.

- ABNT NBR ISO/IEC 27001:2022 (Requisitos do SGSI)

Especifica os requisitos formais para estabelecer, implementar, manter e melhorar continuamente um Sistema de Gestão de Segurança da Informação (SGSI). Adota a abordagem baseada em riscos e exige a elaboração da Declaração de Aplicabilidade (Statement of Applicability - SoA).

- ABNT NBR ISO/IEC 27002:2022 (Código de Práticas e Controles)

Guia de orientação que reúne 93 controles de segurança agrupados em 4 categorias/temas principais: 1. Controles Organizacionais (37 controles); 2. Controles de Pessoas (8 controles); 3. Controles Físicos (14 controles); 4. Controles Tecnológicos (34 controles).

- Gestão de Incidentes de Segurança (modelos de referência)

Dois ciclos muito cobrados: (1) NIST SP 800-61 Rev. 2: Preparação; Detecção e Análise; Contenção, Erradicação e Recuperação; Atividade Pós-Incidente. (2) Modelo de seis etapas do SANS: Preparação, Identificação, Contenção, Erradicação, Recuperação e Lições Aprendidas. Veja a seção 13.

ALERTA DE PROVA - ISO 27001 VERSUS ISO 27002

A ISO/IEC 27001 estabelece os REQUISITOS mandatórios e é a única norma da família que permite certificação formal de uma organização. A ISO/IEC 27002 é um código de boas práticas com DIRETRIZES para a implementação dos controles do Anexo A da ISO 27001.

2. Criptografia Simétrica e Modos de Operação de Cifra de Bloco

A Criptografia Simétrica (ou de Chave Secreta) emprega uma única chave criptográfica compartilhada tanto para o processo de cifração quanto para o processo de decifração da mensagem. Destaca-se pelo altíssimo desempenho computacional e velocidade de processamento, sendo ideal para cifração massiva de bancos de dados fiscais e canais de comunicação em trânsito.

- Algoritmos Simétricos Fundamentais

DES (Data Encryption Standard - chave obsoleta de 56 bits vulnerável a força bruta); 3DES (Triple DES/TDEA - aplica DES três vezes; é lento e obsoleto: o NIST, na SP 800-131A, o depreciou e o proíbe para cifração a partir de 2024); AES (Advanced Encryption Standard / Rijndael - padrão internacional do NIST com blocos fixos de 128 bits e tamanhos de chave de 128, 192 e 256 bits, imune a ataques práticos); RC4 (cifra de fluxo obsoleta); ChaCha20 (cifra de fluxo moderna de alta performance).

- Modos de Operação de Cifra de Bloco

Modos que definem como blocos sequenciais de texto claro são cifrados: 1. ECB (Electronic Codebook - cada bloco é cifrado independentemente com a mesma chave; INSEGURO pois preserva padrões repetitivos do texto original); 2. CBC (Cipher Block Chaining - cada bloco de texto claro sofre operação XOR com o bloco cifrado anterior antes de ser cifrado, exigindo um Vetor de Inicialização / IV aleatório); 3. CFB (Cipher Feedback) e OFB (Output Feedback) - transformam cifras de bloco em cifras de fluxo; 4. CTR (Counter Mode - cifra um contador sequencial com paralelismo total e alta velocidade); 5. GCM (Galois/Counter Mode - provê confidencialidade E autenticidade integrada / AEAD).

- O Desafio da Distribuição de Chaves

O principal ponto fraco da criptografia simétrica reside na necessidade de compartilhamento seguro da chave secreta entre as partes antes do início da comunicação.

A FALHA CRÍTICA DO MODO ECB

O modo ECB (Electronic Codebook) NUNCA deve ser utilizado para dados estruturados ou imagens (ex: pinguim do Linux), pois blocos idênticos de texto claro geram blocos cifrados idênticos, revelando a estrutura visual e os padrões do dado original!

3. Criptografia Assimétrica, Curvas Elípticas e Funções Hash

A Criptografia Assimétrica (ou de Chave Pública) resolve o problema de distribuição de chaves ao utilizar um par de chaves matematicamente correlacionadas: a Chave Pública (amplamente divulgada para qualquer pessoa) e a Chave Privada (mantida em segredo absoluto pelo seu titular). Mensagens cifradas com a chave pública só podem ser decifradas pela chave privada correspondente.

- **Algoritmos Assimétricos Principais**

RSA (baseado na dificuldade matemática de fatoração de números inteiros compostos por dois primos grandes; chaves recomendadas de 2048 ou 4096 bits); ECC (Elliptic Curve Cryptography - baseado no problema do logaritmo discreto em curvas elípticas; oferece segurança equivalente ao RSA com chaves drasticamente menores, ex: ECC de 256 bits equivale a RSA de 3072 bits, consumindo menos bateria e CPU); Diffie-Hellman (protocolo seguro para troca e estabelecimento de uma chave simétrica de sessão através de canal inseguro sem transmitir o segredo).

- **Funções Hash Criptográficas (Resumo Criptográfico)**

Funções matemáticas determinísticas unidirecionais que mapeiam uma entrada de tamanho arbitrário em uma saída de tamanho fixo (Digest). Propriedades obrigatórias: 1. Sentido Único / Unidirecional (impossível reverter o hash para obter a mensagem original); 2. Efeito Avalanche (a alteração de um único bit na entrada muda, em média, cerca de metade dos bits do hash); 3. Resistência a Colisões (computacionalmente inviável encontrar duas entradas distintas X e Y tais que $\text{Hash}(X) = \text{Hash}(Y)$).

- **Famílias de Algoritmos Hash**

MD5 (saída de 128 bits - vulnerável e inseguro); SHA-1 (saída de 160 bits - vulnerável a colisões práticas); SHA-2 (SHA-256 e SHA-512 - padrão robusto, amplamente usado em certificados digitais e assinaturas); SHA-3 (Keccak - arquitetura baseada em esponja criptográfica).

ALERTA DE PROVA - USO DE CHAVES ASSIMÉTRICAS

Para CONFIDENCIALIDADE (sigilo): Cifra com a Chave PÚBLICA do destinatário (apenas o destinatário abre com sua privada). Para AUTENTICIDADE e ASSINATURA DIGITAL: Cifra o hash com a Chave PRIVADA do emissor (qualquer um valida com a pública do emissor).

4. Assinatura Digital, ICP-Brasil e Documentos Fiscais Eletrônicos

A Assinatura Digital é um mecanismo criptográfico que assegura a Autenticidade, a Integridade e o Não Repúdio de documentos eletrônicos. No Brasil, a MP nº 2.200-2/2001 instituiu a ICP-Brasil e prevê (art. 10, §1º) que as declarações constantes de documentos eletrônicos produzidos com certificado ICP-Brasil presumem-se verdadeiras em relação aos signatários. A Lei nº 14.063/2020 classifica as assinaturas eletrônicas em simples, avançada e qualificada; a qualificada é a que usa certificado digital ICP-Brasil.

- Processo de Geração e Validação da Assinatura Digital

Geração: O emissor gera o Hash do documento original e o cifra utilizando a sua CHAVE PRIVADA, anexando a assinatura ao arquivo. Validação: O receptor calcula o Hash do documento recebido e decifra a assinatura com a CHAVE PÚBLICA do emissor; se ambos os hashes forem idênticos, comprova-se que o documento não sofreu alteração (integridade) e partiu inequivocamente do titular da chave privada (autenticidade e não repúdio).

- Infraestrutura de Chaves Públicas Brasileira (ICP-Brasil)

Hierarquia de confiança instituída pela MP 2.200-2/2001: 1. AC-Raiz (Instituto Nacional de Tecnologia da Informação - ITI, única autoridade com certificado autoassinado); 2. Autoridades Certificadoras (ACs de 1º e 2º nível - emitem, suspendem e revogam certificados); 3. Autoridades de Registro (ARs - realizam a identificação presencial e validação documental dos titulares).

- Tipos de Certificados Digitais ICP-Brasil

Tipo A (assinatura digital) e Tipo S (sigilo). Padrão A1: chave gerada por software e armazenada no computador, validade máxima de 1 ano. Padrão A3: chave gerada e armazenada em hardware criptográfico (cartão inteligente ou token), validade de até 5 anos, conforme o DOC-ICP-04.

- Aplicação em Documentos Fiscais (NF-e, NFC-e, EFD)

A Nota Fiscal Eletrônica (modelo 55) é assinada pelo emitente no padrão XML Digital Signature (XML-DSig), com certificado digital ICP-Brasil (e-CNPJ), antes da autorização de uso pela SEFAZ. Segundo o Manual de Orientação do Contribuinte da NF-e, o padrão de assinatura usa RSA com resumo SHA-1 (conferir a versão vigente do manual).

PEGADINHA CLÁSSICA DE ASSINATURA DIGITAL

A assinatura digital NÃO provê confidencialidade (sigilo) do documento, pois o texto da mensagem viaja em texto claro acompanhado do hash assinado. Se houver necessidade de sigilo, o documento assinado deve ser subsequentemente cifrado.

5. Controle de Acesso, Autenticação Multifator e Gestão de Identidade

O Controle de Acesso assegura que apenas usuários, processos e dispositivos autorizados acessem recursos e dados sensíveis da organização, operando através de quatro etapas sucessivas: Identificação, Autenticação, Autorização e Auditoria (Accountability).

- Os 3 Fatores de Autenticação

1. Algo que você SABE (senhas, PINs, perguntas de segurança); 2. Algo que você TEM (smartcard, token OTP, chave física FIDO2/U2F, smartphone); 3. Algo que você É (biometria de impressão digital, reconhecimento facial, íris, voz). Autenticação Multifator (MFA) exige a combinação de pelo menos dois fatores de categorias DISTINTAS (ex: senha + OTP no celular).

- Modelos Formais de Controle de Acesso

DAC (Discretionary Access Control - o proprietário do recurso decide quem tem acesso via listas ACLs); MAC (Mandatory Access Control - o sistema impõe acesso com base em rótulos de sensibilidade e autorizações de segurança / Clearances, ex: Confidencial, Secreto); RBAC (Role-Based Access Control - acessos atribuídos com base nas funções/cargos desempenhados na organização); ABAC (Attribute-Based Access Control - controle dinâmico baseado em atributos do usuário, do recurso, da ação e do ambiente como horário e geolocalização).

- Protocolos de Federação e Identidade Digital

OAuth 2.0 (framework de AUTORIZAÇÃO baseado em tokens de acesso que permite a aplicações de terceiros acessar recursos sem compartilhar senhas); OpenID Connect / OIDC (camada de AUTENTICAÇÃO construída sobre o OAuth 2.0 que fornece ID Tokens); SAML 2.0 (padrão baseado em XML para Single Sign-On corporativo); JWT (JSON Web Tokens - tokens compactos e autocontidos assinados digitalmente, estruturados em três partes separadas por pontos: Header.Payload.Signature).

DIFERENÇA CRÍTICA: OAUTH 2.0 VERSUS OPENID CONNECT

OAuth 2.0 é um protocolo de AUTORIZAÇÃO (concede permissão de acesso via Access Token). OpenID Connect (OIDC) é um protocolo de AUTENTICAÇÃO (comprova a identidade do usuário via ID Token).

6. Segurança de Redes: Firewalls, IDS/IPS, VPN e Protocolos Seguros

A segurança perimetral e de transporte de dados protege as redes corporativas da administração tributária contra interceptações, intrusões não autorizadas e ataques de negação de serviço.

- Gerações e Tipos de Firewalls

1. Filtragem de Pacotes / Stateless (analisa cabeçalhos IP/Porta individualmente sem guardar estado da conexão); 2. Stateful Inspection / Com Estado (mantém uma tabela de estado e inspeciona fluxos completos de conexão TCP); 3. Proxy de Aplicação (atua na camada 7 inspecionando o payload específico do protocolo); 4. Next-Generation Firewall (NGFW - integra stateful inspection, Deep Packet Inspection / DPI, prevenção de intrusão IPS integrada e controle de aplicações em tempo real).

- Sistemas de Detecção e Prevenção de Intrusão (IDS versus IPS)

IDS (Intrusion Detection System): Opera em modo passivo (espelhamento de tráfego), monitora a rede e gera ALERTAS de segurança sem bloquear o tráfego. IPS (Intrusion Prevention System): Opera em modo ativo ('in-line'), monitora o fluxo em tempo real e BLOQUEIA pacotes maliciosos imediatamente. Métodos de Detecção: Baseado em Assinaturas (conhecidas) versus Baseado em Anomalias / Comportamento (detecta ataques de dia zero / Zero-Day).

- VPN e o Protocolo IPsec

Virtual Private Network para túneis criptografados em redes públicas. O protocolo IPsec opera na Camada de Rede (Camada 3) com dois protocolos principais: AH (Authentication Header - provê integridade e autenticidade, mas NÃO cifra os dados) e ESP (Encapsulating Security Payload - provê integridade, autenticidade E CONFIDENCIALIDADE). Modos de Operação: Modo Transporte (cifra apenas o payload IP) versus Modo Túnel (cifra o pacote IP inteiro e anexa um novo cabeçalho IP externo).

- Protocolo TLS 1.3 (Transport Layer Security)

Protocolo de segurança na camada de transporte que protege o HTTPS. O TLS 1.3 eliminou cifras obsoletas (DES, RC4, MD5), reduziu a negociação do Handshake para 1 RTT (ou 0-RTT com retomada de sessão) e tornou mandatório o sigilo progressivo perfeito (Perfect Forward Secrecy - PFS), com troca de chaves efêmera (ECDHE ou DHE).

ALERTA DE PROVA - IPSEC: AH VERSUS ESP

O protocolo AH (Authentication Header) NÃO fornece confidencialidade/sigilo (os dados não são criptografados). Para haver criptografia e sigilo no IPsec, é obrigatório utilizar o protocolo ESP (Encapsulating Security Payload)!

7. Ameaças Cibernéticas, Malwares e Engenharia Social

Compreensão detalhada dos tipos de códigos maliciosos (Malwares), vetores de ataque cibernético e técnicas de manipulação psicológica que visam comprometer sistemas governamentais.

- **Taxonomia dos Malwares**

Vírus: Código malicioso que infecta arquivos legítimos e EXIGE a execução do programa hospedeiro ou ação do usuário para se propagar; Worm: Programa autônomo que se propaga AUTOMATICAMENTE pelas redes explorando vulnerabilidades ativas, sem necessidade de hospedeiro nem intervenção humana; Trojan (Cavalo de Troia): Programa aparentemente inofensivo ou útil que executa funções maliciosas ocultas (abertura de portas traseiras / Backdoors); Spyware: Software espião que coleta dados do usuário sem autorização (subdivide-se em Keyloggers que capturam teclas e Screenloggers que capturam telas); Rootkit: Conjunto de ferramentas complexas que se oculta nas camadas mais profundas do sistema operacional (Kernel) para manter acesso privilegiado furtivo; Ransomware: Malware que sequestra os arquivos da vítima através de criptografia forte, exigindo pagamento de resgate (geralmente em criptomoedas).

- **Técnicas de Engenharia Social**

Phishing (mensagens fraudulentas em massa simulando entidades confiáveis para roubar credenciais); Spear Phishing (phishing altamente direcionado e personalizado a um servidor ou órgão específico); Whaling (ataque direcionado à alta liderança e diretores); Smishing (via SMS); Vishing (via chamadas telefônicas de voz); Pretexting (criação de um cenário fictício para induzir a vítima a fornecer informações restritas).

- **Ataques de Negação de Serviço (DoS e DDoS)**

Ataques volumétricos que visam esgotar os recursos de processamento, memória ou largura de banda de servidores fazendários para torná-los indisponíveis. DDoS (Distributed Denial of Service) emprega milhares de computadores zumbis infectados (Botnets) distribuídos geograficamente.

DIFERENÇA CRÍTICA: VÍRUS VERSUS WORM

Vírus precisa de arquivo HOSPEDEIRO e AÇÃO do usuário para rodar. Worm é AUTÔNOMO, não precisa de hospedeiro e se propaga sozinho pela rede.

8. Segurança em Aplicações Web e OWASP Top 10

A Open Web Application Security Project (OWASP) é a referência mundial de segurança de software e publica periodicamente o Top 10 dos riscos mais críticos em aplicações web. A versão vigente é o OWASP Top 10:2025; a versão de 2021 ainda aparece em provas e materiais e está listada para comparação.

- **OWASP Top 10:2025 (versão vigente)**

A01 Broken Access Control (controle de acesso quebrado; o SSRF foi incorporado a esta categoria); A02 Security Misconfiguration; A03 Software Supply Chain Failures (nova; amplia o antigo A06:2021, componentes vulneráveis e desatualizados); A04 Cryptographic Failures; A05 Injection; A06 Insecure Design; A07 Authentication Failures; A08 Software or Data Integrity Failures; A09 Security Logging and Alerting Failures; A10 Mishandling of Exceptional Conditions (nova).

- **OWASP Top 10:2021 (versão anterior, ainda cobrada)**

A01 Broken Access Control; A02 Cryptographic Failures; A03 Injection; A04 Insecure Design; A05 Security Misconfiguration; A06 Vulnerable and Outdated Components; A07 Identification and Authentication Failures; A08 Software and Data Integrity Failures; A09 Security Logging and Monitoring Failures; A10 Server-Side Request Forgery (SSRF).

- **Ataques de Injeção SQL (SQL Injection - SQLi)**

Ocorre quando dados fornecidos pelo usuário são concatenados diretamente na consulta SQL sem tratamento. Segundo o OWASP SQL Injection Prevention Cheat Sheet, a defesa primária são as consultas parametrizadas (prepared statements). Alternativas: procedimentos armazenados construídos com segurança, validação por lista de permissão (allow-list) e, como último recurso, escape de caracteres. Usar ORMs ajuda, mas não dispensa cuidado com consultas dinâmicas.

- **Cross-Site Scripting (XSS)**

Injeção de scripts maliciosos (geralmente JavaScript) que são executados no navegador de outros usuários legítimos para roubo de cookies de sessão. Tipos: Stored XSS (script persiste no banco de dados), Reflected XSS (script reflete na resposta HTTP imediata) e DOM-based XSS. Prevenção: Codificação contextual de saída (Context-Aware Output Encoding) e uso de cabeçalho Content Security Policy (CSP).

- **Cross-Site Request Forgery (CSRF)**

Induz a vítima autenticada a executar ações indesejadas em uma aplicação web na qual ela possui sessão ativa. Prevenção: Uso de Tokens Anti-CSRF sincronizados e cookies com atributo SameSite=Strict.

A DEFESA PRIMÁRIA CONTRA SQL INJECTION

A defesa primária recomendada pela OWASP é a consulta parametrizada (prepared statements): os dados nunca são interpretados como código SQL. Filtros de caracteres e substituição de aspas, isoladamente, são considerados insuficientes.

9. Lei Geral de Proteção de Dados Pessoais (LGPD - Lei nº 13.709/2018)

A LGPD disciplina o tratamento de dados pessoais em meios físicos e digitais por pessoa natural ou jurídica de direito público ou privado, visando proteger os direitos fundamentais de liberdade, privacidade e o livre desenvolvimento da personalidade.

- **Conceitos Fundamentais da LGPD**

Dado Pessoal (informação relacionada a pessoa natural identificada ou identificável); Dado Pessoal Sensível (dados sobre origem racial ou étnica, convicção religiosa, opinião política, filiação a sindicato ou a organização de caráter religioso, filosófico ou político, dado referente à saúde ou à vida sexual, dado genético ou biométrico); Dado Anonimizado (dado que não permite identificação do titular considerando a utilização de meios técnicos razoáveis e disponíveis na ocasião de seu tratamento - NÃO é considerado dado pessoal para fins da lei).

- **Agentes de Tratamento e o Encarregado**

Controlador (pessoa a quem competem as decisões referentes ao tratamento de dados pessoais); Operador (pessoa que realiza o tratamento de dados em nome do controlador); Encarregado / DPO (pessoa indicada pelo controlador e operador para atuar como canal de comunicação entre o controlador, os titulares dos dados e a ANPD).

- **Princípios da LGPD (Art. 6º)**

Finalidade, Adequação, Necessidade (Minimização de dados), Livre Acesso, Qualidade dos Dados, Transparência, Segurança, Prevenção, Não Discriminação e Responsabilização/Prestação de Contas.

- **As 10 Bases Legais para Tratamento de Dados (Art. 7º)**

1. Consentimento do titular; 2. Cumprimento de obrigação legal ou regulatória pelo controlador; 3. Execução de políticas públicas pela administração pública; 4. Realização de estudos por órgão de pesquisa; 5. Execução de contrato; 6. Exercício regular de direitos em processo judicial ou administrativo; 7. Proteção da vida; 8. Tutela da saúde; 9. Legítimo interesse do controlador (NÃO se aplica a dados sensíveis); 10. Proteção do crédito.

- **Tratamento de Dados pelo Poder Público (Art. 23)**

O Poder Público (SEFAZ) pode tratar dados pessoais SEM consentimento do titular para o cumprimento de suas atribuições legais e a execução de políticas públicas de arrecadação e fiscalização tributária.

ALERTA DE PROVA - CONSENTIMENTO NA ADMINISTRAÇÃO PÚBLICA

A administração pública NÃO depende de consentimento do cidadão para tratar dados pessoais necessários ao cumprimento de obrigação legal ou à execução de suas atribuições fazendárias e fiscalizatórias legítimas (Art. 7º, II e III da LGPD).

10. Armadilhas Conceituais Recorrentes em Segurança da Informação

Pontos conceituais que costumam gerar erro em questões sobre Segurança da Informação, Criptografia e LGPD. Servem de revisão rápida; a base de cada ponto está nas seções anteriores.

- **Pegadinha 1: Chave Privada Assina, Chave Pública Verifica**

Na assinatura digital, o emissor cifra com a sua própria chave PRIVADA. Dizer que assina com a chave pública do destinatário é pegadinha clássica.

- **Pegadinha 2: Assinatura Digital NÃO Garante Sigilo**

Assinatura digital provê Autenticidade, Integridade e Não Repúdio. Sigilo/Confidencialidade exige criptografia separada.

- **Pegadinha 3: Worm NÃO Precisa de Hospedeiro**

Vírus infecta outros arquivos e precisa de execução. Worm é programa independente que navega e se multiplica sozinho pela rede.

- **Pegadinha 4: Modo ECB Preserva Padrões**

O modo ECB cifra blocos de forma isolada, sendo vulnerável a análise de padrões. Modos seguros como CBC usam encadeamento e IV.

- **Pegadinha 5: Hash é Unidirecional e NÃO Decifra**

Funções hash não possuem chave e não são reversíveis. Não existe 'decifrar um hash'; o que se faz é comparar resumos calculados.

- **Pegadinha 6: Consulta Parametrizada é a Defesa Primária contra SQL Injection**

A OWASP recomenda como defesa primária as consultas parametrizadas. Filtrar caracteres ou trocar aspas não é defesa suficiente.

- **Pegadinha 7: OAuth 2.0 é Autorização, OIDC é Autenticação**

OAuth emite tokens de acesso a recursos. Quem identifica o usuário é a camada OpenID Connect com ID Token.

- **Pegadinha 8: IPsec AH NÃO Criptografa**

O cabeçalho AH do IPsec provê apenas autenticação e integridade. Quem realiza criptografia e sigilo é o ESP.

- **Pegadinha 9: Dado Anonimizado NÃO é Dado Pessoal (Salvo Reversão)**

Se a anonimização é irreversível por meios técnicos razoáveis, a LGPD deixa de se aplicar ao dado. Segundo o art. 12, o dado volta a ser tratado como pessoal se o processo puder ser revertido com esforços próprios ou com esforços razoáveis.

- **Pegadinha 10: Legítimo Interesse NÃO se Aplica a Dados Sensíveis**

O rol de bases legais para dados sensíveis (Art. 11 da LGPD) NÃO inclui o Legítimo Interesse.

SÍNTESE FINAL DE MEMORIZAÇÃO

Lembre-se: Chave privada assina; assinatura não esconde dados (não dá sigilo); Worm anda sozinho; no IPsec só o ESP cifra; e o Fisco não pede consentimento na LGPD!

11. Gestão de Riscos: ISO 31000:2018 e ISO/IEC 27005

A gestão de riscos organiza como a instituição identifica, avalia e trata incertezas que afetam seus objetivos. A ISO 31000:2018 é a norma genérica de gestão de riscos, e a ISO/IEC 27005 aplica essa lógica aos riscos de segurança da informação, dando suporte à implementação de um SGSI conforme a ISO/IEC 27001.

- **ISO 31000:2018: três componentes**

Princípios (oito: integrada, estruturada e abrangente, personalizada, inclusiva, dinâmica, melhor informação disponível, fatores humanos e culturais, melhoria contínua), Estrutura (framework) e Processo.

- **Processo de gestão de riscos (ISO 31000:2018)**

Escopo, contexto e critérios; avaliação de riscos (identificação, análise e avaliação); tratamento de riscos. Comunicação e consulta, e monitoramento e análise crítica, ocorrem ao longo de todo o processo, além do registro e relato.

- **Opções de tratamento de riscos (visão da ISO/IEC 27005)**

Modificação (mitigar, reduzindo probabilidade ou impacto com controles), retenção (aceitar), evitação (eliminar a atividade que gera o risco) e compartilhamento (transferir, por exemplo com seguro ou terceirização). Risco residual é o que resta após o tratamento.

- **Cálculo e critérios**

Nível de risco é a combinação de probabilidade e impacto (consequência), avaliado de forma qualitativa ou quantitativa e comparado com os critérios de aceitação da organização.

ALERTA DE PROVA - NORMA CERTO, GUIA CERTO

A ISO/IEC 27001 exige que a organização defina e aplique um processo de avaliação e tratamento de riscos de segurança da informação; a ISO/IEC 27005 é o guia de como fazer essa gestão de riscos. A ISO 31000 não é certificável.

12. Continuidade de Negócios: BIA, ISO 22301, RPO e RTO

Continuidade de negócios é a capacidade de manter ou retomar atividades críticas em nível aceitável após uma interrupção. A ISO 22301 (ABNT NBR ISO 22301:2020) especifica os requisitos de um Sistema de Gestão de Continuidade de Negócios (SGCN) e admite certificação.

- **BIA (Análise de Impacto nos Negócios)**

Identifica as atividades críticas, os impactos da interrupção ao longo do tempo, as dependências (pessoas, sistemas, fornecedores) e as prioridades de recuperação. É a base para definir RTO, RPO e o tempo máximo tolerável de interrupção.

- **RTO, RPO e MTPD**

RTO (Recovery Time Objective): tempo alvo para restabelecer o serviço. RPO (Recovery Point Objective): ponto no tempo até o qual os dados devem ser recuperáveis, ou seja, a perda máxima de dados aceitável (medida em tempo). MTPD (Maximum Tolerable Period of Disruption): tempo máximo de interrupção tolerável; o RTO deve ser menor que o MTPD.

- **PCN e DRP**

O Plano de Continuidade de Negócios cobre a manutenção das atividades críticas; o Plano de Recuperação de Desastres (DRP) trata da recuperação da infraestrutura de TI e dos sistemas.

- **Sites alternativos**

Hot site: ambiente pronto e atualizado, com retomada quase imediata. Warm site: parcialmente equipado, exige carga de dados e configuração. Cold site: espaço e infraestrutura básica, com retomada mais lenta e de menor custo.

- **Regra 3-2-1 de backup**

Manter três cópias dos dados, em duas mídias diferentes, com uma cópia fora do local (offsite).

RPO FALA DE DADOS, RTO FALA DE TEMPO DE RETOMADA

RPO define quanto dado se aceita perder (define a frequência de backup ou replicação). RTO define em quanto tempo o serviço precisa voltar. Replicação síncrona tende a RPO próximo de zero; backups diários implicam RPO de até um dia.

13. Gestão de Incidentes: NIST SP 800-61 e ISO/IEC 27035

Evento de segurança é uma ocorrência que indica possível violação da política ou falha de controles. Incidente de segurança é um ou mais eventos identificados que podem comprometer ativos ou operações. Nem todo evento é incidente.

- **NIST SP 800-61 Rev. 2 (Computer Security Incident Handling Guide)**

Quatro fases: (1) Preparação; (2) Detecção e Análise; (3) Contenção, Erradicação e Recuperação; (4) Atividade Pós-Incidente (lições aprendidas). A Rev. 3, de 2025, reorganiza o guia em torno do NIST CSF 2.0; o edital do CE 2026 cita a Rev. 2.

- **ISO/IEC 27035-1:2023**

Princípios e processo de gestão de incidentes de segurança da informação, em cinco fases: preparar, detectar e relatar, avaliar e decidir, responder e aprender com as lições.

- **Modelo SANS (seis etapas)**

Preparação, Identificação, Contenção, Erradicação, Recuperação e Lições Aprendidas.

- **Contenção antes da erradicação**

Conter isola o problema e limita o dano (por exemplo, isolar o host da rede) antes de eliminar a causa e restaurar o serviço. Preservar evidências é parte do processo.

FASES DIFERENTES CONFORME O MODELO

O NIST agrupa contenção, erradicação e recuperação em uma única fase, enquanto o SANS as separa. Leia o enunciado para saber qual modelo a questão adota.

14. Defesa em Profundidade e Zero Trust

Defesa em profundidade é a estratégia de empregar várias camadas de controles independentes (físicos, de perímetro, de rede, de host, de aplicação, de dados e de pessoas e processos), de modo que a falha de um controle não exponha o ativo. Zero Trust (confiança zero) parte da premissa de que nenhuma rede, usuário ou dispositivo é confiável por padrão: "nunca confie, sempre verifique".

- **Zero Trust segundo a NIST SP 800-207**

O modelo desloca a defesa do perímetro de rede para os recursos. Nenhuma confiança é concedida apenas pela localização na rede; cada acesso é autenticado e autorizado antes de ser permitido.

- **Princípios (tenets) da NIST SP 800-207**

Todas as fontes de dados e serviços são recursos; toda comunicação é protegida, independentemente da localização na rede; o acesso é concedido por sessão; o acesso é decidido por política dinâmica (identidade, estado do dispositivo e comportamento); a integridade e a postura de segurança dos ativos são monitoradas; autenticação e autorização são dinâmicas e rigorosamente aplicadas antes do acesso; o máximo de informação sobre o estado dos ativos é coletado para melhorar a postura de segurança.

- **Componentes lógicos**

Policy Engine (PE, decide a concessão), Policy Administrator (PA, estabelece ou encerra o caminho de comunicação) e Policy Enforcement Point (PEP, aplica a decisão). PE e PA formam o Policy Decision Point (PDP).

- **Microsegmentação**

Divide a rede em segmentos pequenos com políticas próprias, limitando a movimentação lateral de um invasor. É uma técnica comum de implantação de Zero Trust.

ZERO TRUST NÃO É UM PRODUTO

Zero Trust é uma abordagem de arquitetura e de políticas, e não um produto único. Estar na rede interna não concede confiança. VPN, por si só, não implementa Zero Trust.

15. Operações de Segurança: SIEM, SOC, EDR, WAF, NAT e Vulnerabilidades

Ferramentas e práticas que sustentam o monitoramento contínuo e a resposta a ameaças no dia a dia da segurança da informação.

- **SIEM e SOC**

SIEM (Security Information and Event Management) coleta, normaliza e correlaciona logs e eventos de várias fontes e gera alertas. SOC (Security Operations Center) é a equipe, os processos e as tecnologias que monitoram, analisam e respondem a incidentes. O SIEM é ferramenta; o SOC é a função que a utiliza.

- **EDR**

Endpoint Detection and Response: coleta telemetria dos endpoints, detecta comportamento suspeito e permite investigar e responder (por exemplo, isolar a máquina). Vai além do antivírus baseado só em assinaturas.

- **WAF**

Web Application Firewall: filtra e monitora o tráfego HTTP/HTTPS na camada de aplicação, ajudando a bloquear ataques como injeção e XSS. Complementa, mas não substitui, o desenvolvimento seguro.

- **NAT**

Network Address Translation: traduz endereços IP entre redes, muito usado para compartilhar endereços públicos. Não é, por si só, um controle de segurança.

- **CVE e CVSS**

CVE é o identificador público de uma vulnerabilidade conhecida. CVSS é o sistema de pontuação de severidade de 0,0 a 10,0: baixa (0,1 a 3,9), média (4,0 a 6,9), alta (7,0 a 8,9) e crítica (9,0 a 10,0). CVSS mede a severidade técnica, não o risco para a organização.

- **Ciclo de gestão de vulnerabilidades**

Descobrir ativos, varrer vulnerabilidades, priorizar (severidade, exposição e exploração ativa), remediar (correção ou mitigação) e verificar. Varredura de vulnerabilidades identifica fragilidades; teste de intrusão (pentest) tenta explorá-las.

FERRAMENTA DETECTA, PROCESSO RESOLVE

SIEM e EDR detectam e correlacionam; a resposta depende de processo e pessoas (SOC e plano de resposta a incidentes). Prioridade de correção não é só CVSS: considere exposição e exploração ativa.

16. Segurança em Nuvem (ISO/IEC 27017) e IA em Segurança

A ABNT NBR ISO/IEC 27017:2016 é um código de práticas com controles de segurança da informação para serviços em nuvem, baseado na ISO/IEC 27002. A inteligência artificial atua tanto como ferramenta de defesa quanto como alvo e meio de ataque.

- **ISO/IEC 27017**

Complementa a ISO/IEC 27002 com orientações específicas para provedores e clientes de nuvem, incluindo a divisão de papéis e responsabilidades entre eles, a segregação de ambientes virtuais e a gestão de ativos do cliente na nuvem.

- **Responsabilidade compartilhada**

O provedor responde pela segurança da nuvem (infraestrutura); o cliente responde pela segurança na nuvem (dados, identidades e configurações). A fatia do cliente cresce de SaaS para PaaS e para IaaS.

- **IA como alvo e meio de ataque**

Ataques a sistemas de IA: injeção de prompt (prompt injection), envenenamento de dados de treino, exemplos adversariais e extração ou inversão de modelo. IA como ferramenta de ataque: phishing mais convincente e conteúdo sintético (deepfakes).

- **IA como ferramenta de defesa**

Deteção de anomalias e de malware por aprendizado de máquina, priorização de alertas e apoio à triagem em SOC. Exige governança, pois modelos podem errar (falsos positivos e falsos negativos) e ser alvo de manipulação.

- **Referências de IA (conferir na fonte)**

OWASP Top 10 for LLM Applications; NIST AI Risk Management Framework 1.0 (funções Governar, Mapear, Medir e Gerenciar); NIST AI 100-2, taxonomia de ataques de aprendizado de máquina adversarial.

NUVEM: QUEM É RESPONSÁVEL PELO QUÊ

Contratar nuvem não transfere a responsabilidade pelos dados e pelo acesso. Identidades, configuração e classificação de dados continuam sendo do cliente em qualquer modelo de serviço.

17. Aprofundamento: Zero Trust na Prática e DevSecOps

Dois temas de segurança aplicada completam a apostila: a arquitetura Zero Trust em detalhe operacional (além do conceito já citado) e a integração de segurança no ciclo de vida de desenvolvimento de software (DevSecOps), tema recorrente em editais que cobram tanto Segurança quanto Engenharia de Software.

- **Os Pilares Operacionais do Zero Trust (NIST SP 800-207)**

Nunca confiar, sempre verificar: toda solicitação de acesso é autenticada e autorizada de forma explícita, independentemente de vir da rede interna ou externa. Microsegmentação: a rede é dividida em segmentos pequenos e isolados, restringindo o movimento lateral de um invasor após uma primeira violação. Acesso com privilégio mínimo (least privilege) e verificação contínua: a confiança é reavaliada a cada sessão e a cada recurso acessado, não concedida uma única vez no login.

- **SASE (Secure Access Service Edge)**

Modelo que converge funções de rede (SD-WAN) e de segurança (Zero Trust Network Access, firewall como serviço, gateway seguro de web, corretor de segurança de acesso à nuvem) em uma plataforma única entregue a partir da borda da nuvem, adequada a usuários e filiais distribuídos geograficamente, como os postos fiscais de fronteira de uma Secretaria de Fazenda.

- **DevSecOps e os Testes de Segurança na Esteira CI/CD**

SAST (Static Application Security Testing): analisa o código-fonte sem executá-lo, buscando padrões de vulnerabilidade (injeção, uso de funções inseguras), rodado cedo no pipeline (shift left). DAST (Dynamic Application Security Testing): testa a aplicação em execução, simulando ataques externos, útil para vulnerabilidades que só aparecem em tempo de execução. SCA (Software Composition Analysis): audita as dependências e bibliotecas de terceiros do projeto em busca de vulnerabilidades conhecidas (CVEs) e problemas de licenciamento.

- **Shift Left Security**

Princípio de mover as verificações de segurança para o início do ciclo de desenvolvimento (já no code review e no commit), em vez de deixá-las apenas para uma auditoria final antes do deploy, reduzindo o custo de corrigir uma vulnerabilidade encontrada tardiamente.

ALERTA DE PROVA - SAST VERSUS DAST

SAST analisa o CÓDIGO-FONTE parado (caixa branca, sem executar). DAST analisa a APLICAÇÃO rodando (caixa preta, simulando um atacante externo). Um pipeline maduro de DevSecOps usa os dois de forma complementar!

18. Referências e Conferência

Conferência realizada em 21/09/2026, com aprofundamento em 22/09/2026 (seção 17). Fontes consultadas ou citadas nesta apostila; os itens indicados como conferir dependem de texto pago (normas ISO/ABNT) ou de versão vigente.

- **Normas e guias**

ABNT NBR ISO/IEC 27001:2022; 27002:2022; 27005:2023; 27017:2016; 27035-1:2023; ABNT NBR ISO 22301:2020; ISO 31000:2018; NIST SP 800-61 Rev. 2; NIST SP 800-207; NIST SP 800-131A; OWASP Top 10:2025 (owasp.org/Top10/2025).

- **Legislação e ICP-Brasil**

Lei nº 13.709/2018 (LGPD); MP nº 2.200-2/2001; Lei nº 14.063/2020; DOC-ICP-04 (prazos de validade: A1 de 1 ano, A3 de até 5 anos).

- **Corrigido nesta revisão**

3DES não é mais seguro; efeito avalanche (cerca de metade dos bits); NF-e usa RSA com SHA-1; assinatura ICP-Brasil não é descrita em lei como equiparada a firma reconhecida; SQL Injection: consulta parametrizada é defesa primária, não única; OWASP Top 10:2025 incluída.

- **A conferir**

Rótulos e quantidades de controles das normas ISO citadas seguem o conteúdo público conhecido; verificar no texto oficial da ABNT ao estudar. Possível mudança de nomenclatura de certificados ICP-Brasil anunciada em 2025: consultar o ITI.

REGRA DE CONTEÚDO

Este material não afirma nada sem fonte. Se encontrar divergência com a norma vigente, a norma prevalece.

GLOSSÁRIO DE SIGLAS E ABREVIATURAS

Consulte abaixo o significado e a expansão explicativa de todas as siglas contábeis, tributárias e de TI presentes nas apostilas de preparação:

ACID	Atomicidade, Consistência, Isolamento e Durabilidade. Propriedades fundamentais para transações em SGBDs.
BI	Business Intelligence. Inteligência de Negócios para mineração e análise estratégica de dados.
CAP	Consistência, Disponibilidade e Tolerância a Partições. Teorema limitador para sistemas distribuídos.
CEBRASPE	Centro de Seleção e de Promoção de Eventos. Banca examinadora oficial de concursos públicos.
CFC	Conselho Federal de Contabilidade. Órgão responsável pela edição das NBCs no território nacional.
CIAP	Controle de Crédito de ICMS do Ativo Permanente. Controle fiscal de apropriação de créditos de bens imobilizados.
CID	Confidencialidade, Integridade e Disponibilidade. Pilares de sustentação da Segurança da Informação.
COBIT	Control Objectives for Information and Related Technologies. Framework global de Governança de TI.
CPC	Comitê de Pronunciamentos Contábeis. Emissor de normas convergentes com padrões internacionais.
FGV	Fundação Getulio Vargas. Banca examinadora de certames e instituição de pesquisa econômica.
ICMS	Imposto sobre Operações Relativas à Circulação de Mercadorias e Prestações de Serviços de Transporte.
IPVA	Imposto sobre a Propriedade de Veículos Automotores. Tributo de competência estadual.
ITD	Imposto sobre Transmissão Causa Mortis e Doação. Tributo sobre heranças e doações na Bahia.
ITIL	Information Technology Infrastructure Library. Boas práticas de Gerenciamento de Serviços de TI.
KDD	Knowledge Discovery in Databases. Processo sistemático de descoberta de conhecimento em bases de dados.
LDO	Lei de Diretrizes Orçamentárias. Define as metas e prioridades para o orçamento do exercício seguinte.
LOA	Lei Orçamentária Anual. Estima as receitas e fixa as despesas públicas para o exercício financeiro.
NBC TA	Normas Brasileiras de Contabilidade Técnicas de Auditoria Independente. Alinhadas ao padrão internacional.
NBC TI	Normas Brasileiras de Contabilidade Técnicas de Auditoria Interna. Foco nos processos organizacionais.
NoSQL	Not Only SQL. Família de SGBDs não relacionais estruturados para alto desempenho e escalabilidade.
OLAP	Online Analytical Processing. Ferramentas analíticas baseadas em cubos de dados multidimensionais.
PAF-BA	Processo Administrativo Fiscal do Estado da Bahia. Lei nº 3.956/1981 que regula o contencioso.
PPA	Plano Plurianual. Planejamento estratégico governamental de médio prazo (4 anos).
RICMS-BA	Regulamento do ICMS do Estado da Bahia. Decreto regulamentador do principal imposto estadual.
RUP	Rational Unified Process. Processo de desenvolvimento de software disciplinado e preditivo.
SEFAZ-BA	Secretaria da Fazenda do Estado da Bahia. Órgão de arrecadação e controle fiscal baiano.

SGBD	Sistema de Gerenciamento de Banco de Dados. Software de controle e armazenamento seguro de dados.
SQL	Structured Query Language. Linguagem declarativa padrão para consulta em SGBDs relacionais.
TI	Tecnologia da Informação. Recursos de hardware, software e infraestrutura de rede corporativa.
XP	Extreme Programming. Metodologia ágil de engenharia de software focada em excelência técnica.